Procédure de validation de `D1-L15-01` - staging uniquement

Statut : procédure documentaire, non exécutée. Aucun déploiement n'a été lancé et aucune base de production n'a été consultée ou modifiée. Cette procédure ne vaut pas preuve de réussite et ne marque pas `D1-L15-01` comme terminée.

1. Objet et limites

Valider `scripts/deploy.php` sur une instance de **staging isolée** : renouvellement des identifiants des quatre comptes de démonstration, adresses sur des domaines réservés en `.invalid`, validité des empreintes bcrypt et connexion de test à l'application.

La procédure ne demande ni ne permet de promouvoir le changement en production. Ne pas utiliser de données personnelles ou de sauvegarde de production : préparer une base de staging avec des données synthétiques. Si l'hôte, le nom de base ou les identifiants ne sont pas confirmés comme étant ceux du staging, **arrêter sans exécuter le script**.

2. Préparer un environnement isolé

1. Utiliser un clone de travail ou un conteneur réservé au staging, sur un réseau qui ne peut pas joindre la base de production. Les identifiants de production ne doivent pas y être disponibles.

2. Vérifier que `scripts/deploy.php` correspond au commit à valider et que `scripts/deploy.php --db` ne sera lancé que depuis cet environnement isolé.

3. Configurer explicitement la cible staging et un compte SQL dédié, limité aux opérations nécessaires sur la base de staging. Ne pas reprendre le nom de base par défaut `minishop` sans confirmation de la cible.

4. **Point de configuration important :** le script lit `app/Config/env.php` s'il existe et ses valeurs (`db_host`, `db_port`, `db_name`, `db_user`, `db_pass`) priment sur les variables d'environnement. Sur la copie staging, vérifier ce fichier ou l'absenter pour utiliser les variables. Le script n'exploite pas le fichier `.env` comme la configuration applicative ; son repli attend notamment `DB`, `DB_HOST`, `DB_PORT`, `DB_USER` et `DB_PASS` (`DB_PASSWORD` seul n'est pas lu par ce script).

5. Désactiver les envois de courriels sortants ou les rediriger vers un bac à sable. Le mode `--emails=demo` doit conserver les adresses en `.invalid` ; ne pas employer `--emails=keep`.

3. Confirmer la cible et sauvegarder le staging

Renseigner les variables `STAGE_DB_*` depuis le gestionnaire de secrets de l'environnement. Ne pas inscrire de mot de passe dans la commande, l'historique du shell, le dépôt ou un journal partagé. Le `-p` ci-dessous demande le secret de manière interactive.

```
mysql \
  --host="$STAGE_DB_HOST" \
```

```
  --port="${STAGE_DB_PORT:-3306}" \
  --user="$STAGE_DB_USER" -p \
  --database="$STAGE_DB_NAME" \
  --execute="SELECT DATABASE() AS db, @@hostname AS host, @@port AS port, @@read_only AS
read_only;"
```

Comparer le nom de base et l'hôte retournés à la fiche de staging approuvée. La base doit être la base staging attendue et accessible en écriture pour ce test. En cas de différence ou de doute, arrêter.

Créer ensuite une sauvegarde **de staging uniquement**, en dehors du dépôt et avec des permissions privées :

```
umask 077
STAGING_BACKUP="$HOME/minishop-staging-before-$(date +%Y%m%d-%H%M%S).sql"
mysqldump \
  --host="$STAGE_DB_HOST" \
  --port="${STAGE_DB_PORT:-3306}" \
  --user="$STAGE_DB_USER" -p \
  --single-transaction --routines --triggers \
  "$STAGE_DB_NAME" > "$STAGING_BACKUP"
chmod 600 "$STAGING_BACKUP"
```

Avant toute modification, vérifier que la base contient exactement le compte administrateur de démonstration et les trois comptes clients prévus par le jeu de données :

```
SELECT
  (SELECT COUNT(*) FROM administrateur
    WHERE nom = 'Nguyen' AND prenom = 'Alice') AS administrateur_demo,
  (SELECT COUNT(*) FROM client
    WHERE (nom, prenom) IN (
      ('Dupont', 'Alice'), ('Martin', 'Bruno'), ('Moretti', 'Carla')
    )) AS clients_demo;
```

Résultat attendu : `administrateur_demo = 1` et `clients_demo = 3`. Sinon, arrêter et réinitialiser le **staging** selon sa procédure d'exploitation avant de reprendre.

4. Exécuter le contrôle sur staging seulement

Le script imprime les adresses et mots de passe générés. Exécuter la commande depuis le clone staging, sur une session privée, en redirigeant toute sa sortie vers un fichier temporaire protégé. Ce fichier contient des secrets en clair : ne pas l'ajouter à Git, à une MR, à un ticket, à un artefact CI ou à une preuve partagée.

```
umask 077
PRIVATE_LOG="$(mktemp "${TMPDIR:-/tmp}/minishop-d1-l15-01.XXXXXX")"
chmod 600 "$PRIVATE_LOG"

DB_HOST="$STAGE_DB_HOST" \
DB_PORT="${STAGE_DB_PORT:-3306}" \
DB="$STAGE_DB_NAME" \
DB_USER="$STAGE_DB_USER" \
```

```
DB_PASS="$STAGE_DB_PASS" \
  php scripts/deploy.php --db --emails=demo --passwords=random \
  >"$PRIVATE_LOG" 2>&1
```

Si `app/Config/env.php` contient une configuration, vérifier une dernière fois qu'elle pointe exclusivement sur le staging : les variables ci-dessus ne la remplacent pas. Ne pas ajouter `--write-sql` : cette option réécrit `sql/01_minishop_schema.sql` dans le checkout. Ne pas utiliser `--seed` pour cette validation.

Conserver le journal uniquement dans l'espace privé nécessaire à la vérification des identifiants de staging. Ne pas copier ses lignes de mots de passe dans le compte rendu ; après les essais, supprimer le fichier selon les règles d'effacement des secrets de l'environnement.

5. Contrôles attendus

1. Le processus se termine avec le code `0` et la sortie privée indique la mise à jour de la base.

2. Exécuter des requêtes de contrôle qui ne retournent **aucune empreinte brute**. Vérifier pour l'administrateur `Nguyen Alice` et chaque client `Dupont Alice`, `Martin Bruno`, `Moretti Carla` : une ligne correspondante, une adresse `admin-demo-...@minishop.invalid` ou `demo-...@example.invalid`, une empreinte bcrypt de 60 caractères (`LEFT(mot_de_passe_hash, 4) = '$2y$'`) et une authentification valide. Les résultats peuvent être des booléens ou des comptes, jamais les valeurs d'empreinte.

3. Depuis l'interface privée du staging, tester les connexions de démonstration avec les identifiants générés, puis vérifier une page client et une page administrateur autorisée. N'effectuer ni paiement, ni envoi réel de courriel, ni action sur des données hors du jeu synthétique.

4. Vérifier que la base et le serveur testés sont toujours ceux du staging. Consigner seulement le commit, l'alias non sensible du staging, l'heure, les contrôles réussis/échoués et le résultat. Expurger les mots de passe, empreintes, secrets de connexion et toute donnée personnelle.

6. Échec et retour arrière

À la première anomalie, arrêter l'application de staging et ne pas poursuivre vers un autre environnement. Si un retour arrière est nécessaire, restaurer **uniquement** `$STAGING_BACKUP` dans la base de staging confirmée, avec les accès staging. Ne jamais réutiliser cette commande ou cette sauvegarde sur une base de production.

7. Critère de clôture

`D1-L15-01` ne pourra être réévaluée qu'après l'exécution autorisée de ces contrôles sur staging et la conservation d'une preuve expurgée. Le présent document fournit la procédure ; il ne déclare aucun déploiement ou test réalisé et n'autorise pas une opération de production.